

NEXACORP

Documentation Technique

Infrastructure IT Complete Simulation Environnement Professionnel

Champ	Valeur
Projet	Infrastructure NexaCorp Labo VMware
Version	1.0
Date	Mai 2026
Auteur	Administrateur NexaCorp
Statut	Complete

1. Architecture Réseau

1.1 Description Générale

Le laboratoire NexaCorp simule le système d'information d'une PME fictive. L'infrastructure tourne entièrement sur une seule machine hôte via VMware Workstation et comprend cinq machines virtuelles interconnectées via trois segments réseau distincts, gérés par un firewall pfSense.

1.2 Machine Hôte

Composant	Détail
Modèle	Lenovo ThinkPad
Processeur	Intel Core i5
RAM	12 Go
Stockage	256 Go SSD
Hyperviseur	VMware Workstation

1.3 Segments Réseau VMware

Réseau VMware	Type	Subnet	Usage
VMnet8	NAT	192.168.110.x (auto)	WAN pfSense acces internet
VMnet2	Host-Only	192.168.10.0/24	LAN AD, clients, logs
VMnet3	Host-Only	192.168.20.0/24	DMZ serveur web

1.4 Plan d'Adressage IP

VM	Rôle	OS	IP	Réseau
VM1 pfSense	Firewall/Routeur	pfSense 2.8	WAN:192.168.110.146 LAN:192.168.10.1 DMZ:192.168.20.1	VMnet8/2/3
VM2 WinSrv-AD	AD/DNS/DHCP	Windows Server 2022	192.168.10.10/24	VMnet2
VM3 Linux-Web	Serveur Web	Ubuntu Server 24	192.168.20.10/24	VMnet3
VM4 Linux-Log	Logs centraux	Ubuntu Server 24	192.168.10.20/24	VMnet2
VM5 Win10-Client	Poste Client	Windows 10 Pro	DHCP 192.168.10.100	VMnet2

1.5 Ressources Allouées

VM	RAM	vCPU	Disque
pfSense	512 Mo	1	8 Go
WinSrv-AD	2.5 Go	2	40 Go
Linux-Web	1 Go	1	20 Go
Linux-Log	1 Go	1	20 Go

VM	RAM	vCPU	Disque
Win10-Client	2 Go	2	40 Go
Total	7 Go / 12 Go	7 vCPUs	128 Go

1.6 Flux Réseau

Le trafic entre les segments suit ces règles fondamentales :

- Internet -> WAN pfSense -> DMZ (ports 80/443 uniquement via NAT Port Forward)
- LAN -> WAN : autorise via NAT pfSense
- LAN -> DMZ : autorise sur ports 80, 443, 2222
- DMZ -> LAN : bloque sauf port 514 UDP/TCP vers Linux-Log
- DMZ -> Internet : autorise pour mises à jour
- WAN -> LAN : bloque implicitement par pfSense

2. Procédures d'Installation

2.1 VM1 pfSense

Configuration console

```
WAN = em0 (VMnet8 NAT)
LAN = em1 (VMnet2) -> IP 192.168.10.1/24
OPT1 = em2 (VMnet3) -> IP 192.168.20.1/24 (renomme DMZ)
```

Interface web <https://192.168.10.1>

```
System > General : hostname=nexacorp-fw, domain=nexacorp.local, DNS=8.8.8.8
Firewall > NAT > Outbound (Hybride) :
  192.168.10.0/24 -> WAN Address
  192.168.20.0/24 -> WAN Address
Firewall > NAT > Port Forward :
  WAN:80 -> 192.168.20.10:80
  WAN:443 -> 192.168.20.10:443
```

2.2 VM2 Windows Server 2022

Réseau et rôles

```
IP: 192.168.10.10/24 Gateway: 192.168.10.1 DNS: 127.0.0.1 Nom: NEXASRV01
Rôles: Active Directory Domain Services + DNS Server + DHCP Server
Domaine: nexacorp.local
DHCP Scope: 192.168.10.100-200 | Gateway: 192.168.10.1 | DNS: 192.168.10.10
```

Structure Active Directory

```
nexacorp.local
  OU=Utilisateurs : alice.dupont (IT-Admins), bob.martin (Commerciaux),
                  claire.ndong (Direction), svc-web (service)
  OU=Groupes      : IT-Admins, Commerciaux, Direction (Global, Sécurité)
  OU=Ordinateurs  : WIN10-CLIENT
```

2.3 VM3 Linux-Web (Apache)

Réseau, Apache, SSH, UFW

```
IP: 192.168.20.10/24 Gateway: 192.168.20.1 DNS: 192.168.20.1
sudo apt install -y apache2 ufw
# SSH securiser :
Port 2222 | PermitRootLogin no | PasswordAuthentication no
AllowUsers adminweb | MaxAuthTries 3 | X11Forwarding no
# Override systemd pour port 2222 :
ExecStart=/usr/sbin/sshd -D -p 2222
# UFW :
deny incoming | allow from LAN port 2222 | allow 80/tcp | allow 443/tcp
```

2.4 VM4 Linux-Log (Rsyslog + Fail2ban)

Rsyslog serveur

```
module(load="imudp") input(type="imudp" port="514")
module(load="imtcp") input(type="imtcp" port="514")
$template RemoteLogs, "/var/log/remote/%HOSTNAME%/%PROGRAMNAME%.log"
*. * ?RemoteLogs
```

```
& ~  
sudo chown -R syslog:adm /var/log/remote
```

Rsyslog client sur Linux-Web

```
*.* @192.168.10.20:514 # UDP  
*.* @@192.168.10.20:514 # TCP  
module(load="imfile")  
input(type="imfile" File="/var/log/apache2/access.log" Tag="apache-access")
```

NXLog sur WinSrv-AD

```
<Extension syslog> Module xm_syslog </Extension>  
<Input in> Module im_msvistalog </Input>  
<Output out> Module om_udp Host 192.168.10.20 Port 514  
    Exec $Hostname = "NEXASRV01"; to_syslog_ietf(); </Output>  
<Route 1> Path in => out </Route>
```

Fail2ban

```
[DEFAULT] bantime=3600 findtime=600 maxretry=3 backend=systemd  
[sshd]     enabled=true port=2222 logpath=/var/log/auth.log  
[apache-auth] enabled=true port=80,443  
    logpath=/var/log/remote/linuxweb/apache-access.log maxretry=5
```

3. Politique de Sécurité Appliquée

3.1 Règles Firewall pfSense

Règles Floating

Règle	Interface	Direction	Source	Destination
Autoriser LAN -> pfSense	LAN	in	LAN subnets	This firewall
Autoriser ping DMZ -> pfSense	DMZ	in	192.168.20.10	This firewall

Règles LAN

Action	Source	Destination	Port	Description
Pass	LAN subnets	Any	Any	LAN vers WAN
Pass	LAN subnets	192.168.20.10	80,443,2222	LAN vers DMZ
Pass	192.168.10.10	This firewall	443	Admin pfSense (WinSrv)
Pass	192.168.10.100	This firewall	443	Admin pfSense (Client)
Block	Any	Any	Any	Bloquer tout le reste

Règles DMZ (ordre de priorité)

Ordre	Action	Source	Destination	Port	Description
1	Block	DMZ subnets	LAN subnets	Any	Bloquer DMZ -> LAN
2	Pass	DMZ subnets	192.168.10.20	514 UDP	Logs -> Linux-Log
3	Pass	DMZ subnets	192.168.10.20	514 TCP	Logs -> Linux-Log
4	Pass	DMZ subnets	Any	Any	DMZ -> Internet

3.2 GPO Active Directory

GPO1 Politique de Mots de Passe

Paramètre	Valeur	Justification
Longueur minimale	10 caractères	Resistance bruteforce
Complexité	Activée	Mix majuscules/minuscules/chiffres/spéciaux
Durée maximale	90 jours	Rotation régulière obligatoire
Seuil verrouillage	5 tentatives	Blocage attaques bruteforce
Durée verrouillage	15 minutes	Déblocage automatique

GPO2 Restrictions Accès (filtree Commerciaux + Direction)

Paramètre	Groupe concerne	Effet
Interdire Panneau de config	Commerciaux + Direction	Impossible de modifier la config système
Connexion locale interdite	Commerciaux	Impossible de se connecter physiquement
Connexion RDP interdite	Commerciaux + Direction	Pas de bureau a distance

GPO3 Journalisation Avancée

Catégorie audit	Succès	Echec
Account Logon	Oui	Oui
Logon/Logoff	Oui	Oui
Object Access	Non	Oui
Privilege Use	Non	Oui
Account Management	Oui	Oui

3.3 Hardening Linux

- Mises à jour automatiques de sécurité (unattended-upgrades)
- Services inutiles désactivés : ModemManager, fwupd, multipathd, upower
- Paramètres kernel sécurisés : ip_forward=0, tcp_syncookies=1, randomize_va_space=2
- Comptes système verrouillés (sync, games, news)
- Logs sudo configurés dans /var/log/sudo.log
- Intégrité des fichiers vérifiée avec AIDE
- UFW configure avec politique deny par défaut
- Bannière SSH légale configurée sur tous les serveurs

3.4 Hardening Windows Server

- RemoteRegistry désactivé
- Service Fax désactivé
- RDP restreint au LAN uniquement (192.168.10.0/24)
- Journal Security augmente à 200 Mo
- Principe du moindre privilège vérifié sur Domain Admins
- NXLog configure pour export des événements vers Linux-Log

3.5 Sécurité SSH

Paramètre	Valeur	Raison
Port	2222	Eviter les scans sur port 22
PermitRootLogin	no	Interdire connexion root directe
PasswordAuthentication	no	Forcer clé cryptographique
MaxAuthTries	3	Limiter les tentatives
AllowUsers	adminweb/adminlog	Restreindre aux comptes dédiés
X11Forwarding	no	Désactiver GUI distante

4. Rapport d'Audit de Sécurité

Un mini-audit interne a été réalisé : introduction volontaire de failles, détection par outils open source, documentation et correction. Simulation d'un pentest interne basique.

4.1 Failles Introduites

#	Faille	Machine	Niveau de risque
1	SSH root autorise + auth par mot de passe	Linux-Web	CRITIQUE
2	Service Telnet installe et actif	Linux-Web	CRITIQUE
3	Fichier sensible lisible par tous (chmod 644)	Linux-Web	ELEVE
4	Compte AD sans expiration de mot de passe	WinSrv-AD	MOYEN
5	Règle firewall DMZ trop permissive (any -> any)	pfSense	ELEVE

4.2 Méthodes de Détection

Outil 1 Nmap

```
sudo nmap -sV -sC -O -p- 192.168.20.10 -oN /tmp/scan_vm3.txt
Résultat : port 22 (SSH PermitRootLogin=yes), port 23 (telnet), port 80 (http)
```

Outil 2 Lynis

```
sudo lynis audit system 2>&1 | grep -E "WARNING|SUGGESTION"
[WARNING] PermitRootLogin is set to YES
[WARNING] Telnet is enabled
[SUGGESTION] File permissions on /etc/nexacorp.conf
```

Outil 3 PowerShell AD

```
Search-ADAccount -PasswordNeverExpires -UsersOnly | Select-Object Name,
PasswordNeverExpires
Résultat : bob.martin PasswordNeverExpires : True
```

Outil 4 Permissions fichiers

```
find /etc -maxdepth 1 -type f -perm /o+r 2>/dev/null
stat /etc/nexacorp.conf -> Access: (0644/-rw-r--r--) = FAILLÉ
```

4.3 Corrections Appliquées

Faille	Commande de correction	Validation
SSH root	PermitRootLogin no + PasswordAuthentication no + restart ssh	Permission denied (publickey)
Telnet	apt remove telnetd + systemctl disable inetd	Port 23 closed (Nmap)
Fichier chmod 644	chmod 600 /etc/nexacorp.conf + chown root:root	-rw----- confirme
Pwd AD sans expiration	Set-ADUser bob.martin - PasswordNeverExpires \$false	PasswordNeverExpires=False
Regle DMZ permissive	Supprimer regle any dans pfSense DMZ	Regle supprimée confirmée

4.4 Tableau Récapitulatif

Faible	Détectée par	Corrigée	Statut
SSH root + mot de passe	Nmap + Lynis	Oui	Résolu
Telnet actif	Nmap	Oui	Résolu
Fichier chmod 644	find + stat	Oui	Résolu
Pwd AD sans expiration	Search-ADAccount	Oui	Résolu
Règle DMZ permissive	Revue pfSense	Oui	Résolu

5. Résumé Exécutif

5.1 Infrastructure Déployée

L'infrastructure NexaCorp a été entièrement déployée et validée. Cinq machines virtuelles interconnectées via trois segments réseau, avec pfSense assurant la segmentation selon le principe du moindre privilège.

5.2 Services Opérationnels

Service	Machine	Statut
Firewall/Routeur pfSense	VM1	Opérationnel
Active Directory nexacorp.local	VM2 NEXASRV01	Opérationnel
DNS Server	VM2 NEXASRV01	Opérationnel
DHCP Server	VM2 NEXASRV01	Opérationnel
Serveur Web Apache	VM3 Linux-Web	Opérationnel
SSH sécurisé port 2222	VM3 + VM4	Opérationnel
Centralisation Logs Rsyslog	VM4 Linux-Log	Opérationnel
Fail2ban anti-bruteforce	VM4 Linux-Log	Opérationnel
NXLog logs Windows	VM2 WinSrv-AD	Opérationnel
Poste client Windows 10	VM5 Win10-Client	Opérationnel

5.3 Bonnes Pratiques Appliquées

- Segmentation réseau en trois zones (WAN, LAN, DMZ) avec filtrage strict
- Principe du moindre privilège appliqué à chaque couche
- Authentification SSH par clé cryptographique uniquement (ed25519)
- Centralisation des logs pour détection des incidents
- GPO pour application centralisée des politiques de sécurité
- Fail2ban pour protection automatique contre le brute-force
- Hardening système (sysctl, AIDE, services désactivés)
- Audit de sécurité avec détection et correction de 5 failles
- Mises à jour automatiques de sécurité configurées
- Bannière légale SSH sur tous les serveurs Linux